Electronic Mail Security

Secure/Multipurpose Internet Mail Extension (S/MIME)

Operational Description

- S/MIME provides four message-related services: authentication, confidentiality, compression, and email compatibility

Function	Typical Algorithm	Typical Action
Digital signature	RSA/SHA-256	A hash code of a message is created using SHA-256. This message digest is encrypted using SHA-256 with the sender's private key and included with the message.
Message encryption	AES-128 with CBC	A message is encrypted using AES-128 with CBC with a one-time session key generated by the sender. The session key is encrypted using RSA with the recipient's public key and included with the message.
Compression	unspecified	A message may be compressed for storage or transmission.
Email compatibility	Radix-64 conversion	To provide transparency for email applications, an encrypted message may be converted to an ASCII string using radix-64 conversion.

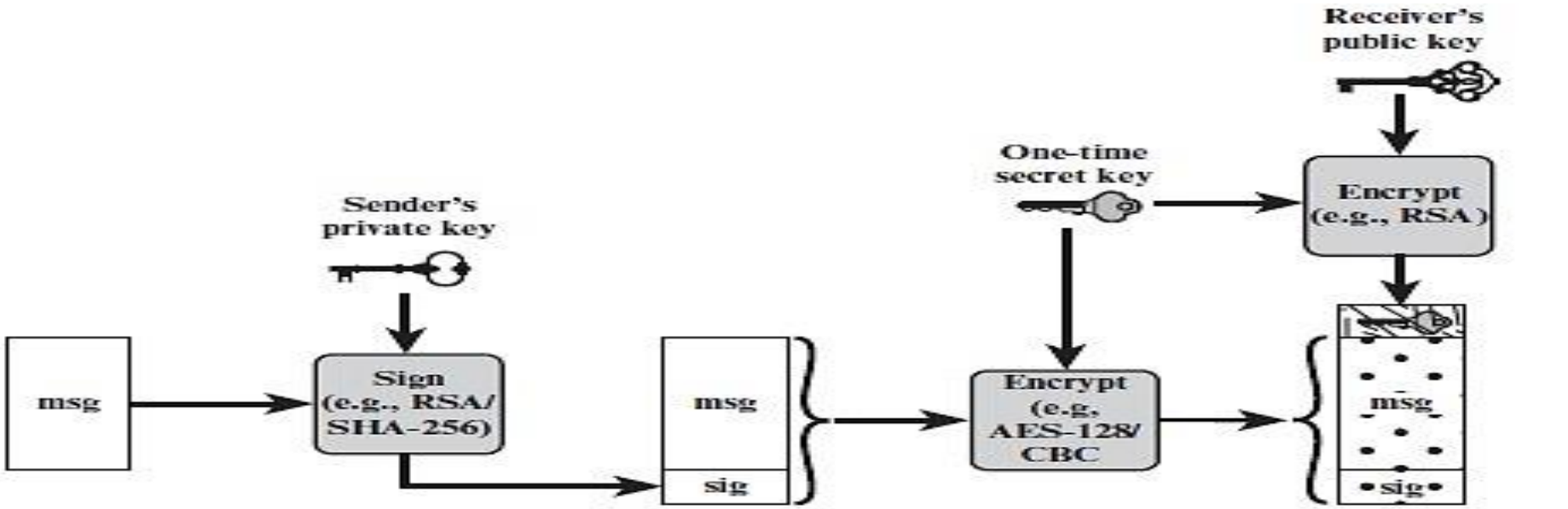
Authentication

- **Authentication is provided using a digital signature.**
- **Most commonly RSA with SHA-256 is used.**
- The sequence is as follows:
  - ✓ The sender creates a message.
  - ✓ SHA-256 is used to generate a 256-bit message digest of the message.
  - ✓ The message digest is encrypted with RSA using the sender's private key, and the result is appended to the message. Also appended is identifying information for the signer, which will enable the receiver to retrieve the signer's public key.
  - ✓ The receiver uses RSA with the sender's public key to decrypt and recover the message digest.
  - ✓ The receiver generates a new message digest for the message and compares it with the decrypted hash code. If the two match, the message is accepted as authentic.

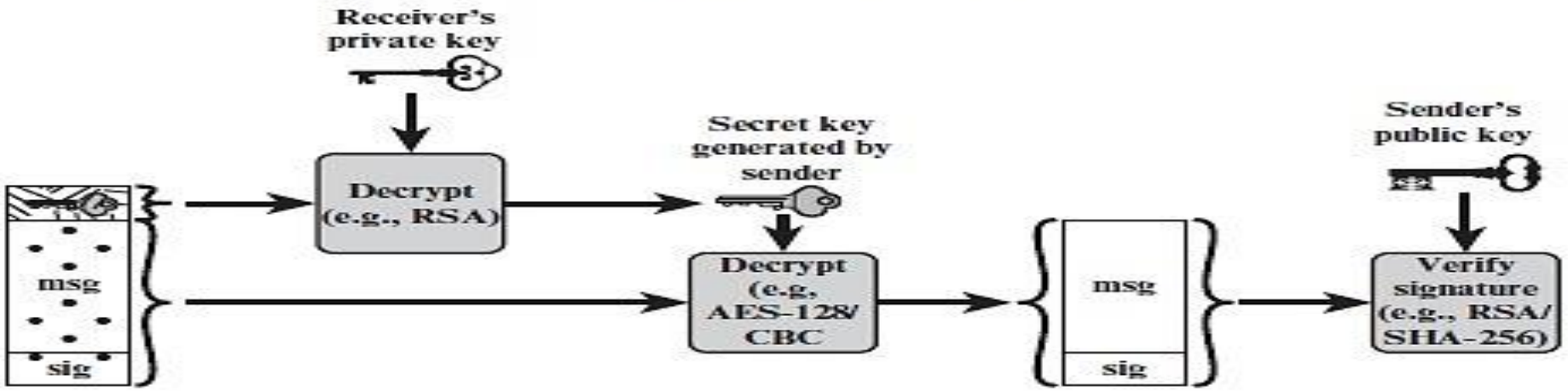
Confidentiality

- **S/MIME provides confidentiality by encrypting messages.**
- **Most commonly AES with a 128-bit key is used, with the cipher block chaining (CBC) mode.**
- **The key itself is also encrypted, typically with RSA.**
- In S/MIME, each symmetric key, referred to as a content-encryption key, is used only once. That is, a new key is generated as a random number for each message. Because it is to be used only once, the content-encryption key is bound to the message and transmitted with it.
- To protect the key, it is encrypted with the receiver's public key.
- The sequence can be described as follows:
  - ✓ The sender generates a message and a random 128-bit number to be used as a content-encryption key for this message only.
  - ✓ The message is encrypted using the content-encryption key.
  - ✓ The content-encryption key is encrypted with RSA using the recipient's public key and is attached to the message.
  - ✓ The receiver uses RSA with its private key to decrypt and recover the content-encryption key.
  - ✓ The content-encryption key is used to decrypt the message.

Confidentiality and Authentication



(a) Sender signs, then encrypts message



(b) Receiver decrypts message, then verifies sender's signature

Email Compatibility

- When S/MIME is used, at least part of the block to be transmitted is encrypted.
- If only the signature service is used, then the message digest is encrypted (with the sender's private key).
- If the confidentiality service is used, the message plus signature (if present) are encrypted (with a one-time symmetric key).
- Part or all of the resulting block consists of a stream of arbitrary 8-bit octets.
- Many electronic mail systems only permit the use of blocks consisting of ASCII text.
  - To accommodate this restriction, S/MIME provides the service of converting the raw 8-bit binary stream to a stream of printable ASCII characters, a process referred to as 7-bit encoding.
  - The scheme typically used for this purpose is Base64 conversion.
  - Each group of three octets of binary data is mapped into four ASCII characters.

Compression

- S/MIME also offers the ability to compress a message.
- Benefit of saving space both for email transmission and for file storage.
- Compression can be applied in any order concerning the signing and message encryption operations.
- RFC 5751 provides the following guidelines:
  - Compression of binary encoded encrypted data is discouraged, since it will not yield significant compression. Base64 encrypted data could very well benefit.
  - If a lossy compression algorithm is used with signing, need to compress first, then sign.

Message Content Types

- S/MIME uses the following message content types, which are defined in RFC 5652, Cryptographic Message Syntax:
  - ✓ **Data:** Inner MIME-encoded message content, which may then be encapsulated in a SignedData, EnvelopedData, or CompressedData content type.
  - ✓ **SignedData:** Used to apply a digital signature to a message.
  - ✓ **EnvelopedData:** Consists of encrypted content of any type and encrypted content encryption keys for one or more recipients.
  - ✓ **CompressedData:** Used to apply data compression to a message.

Approved Cryptographic Algorithms

Function	Requirement
Create a message digest to be used in forming a digital signature.	MUST support SHA-256 SHOULD support SHA-1 Receiver SHOULD support MD5 for backward compatibility
Use message digest to form a digital signature.	MUST support RSA with SHA-256 SHOULD support —DSA with SHA-256 —RSASSA-PSS with SHA-256 —RSA with SHA-1 —DSA with SHA-1 —RSA with MD5
Encrypt session key for transmission with a message.	MUST support RSA encryption SHOULD support —RSAES-OAEP —Diffie–Hellman ephemeral-static mode
Encrypt message for transmission with a one-time session key.	MUST support AES-128 with CBC SHOULD support —AES-192 CBC and AES-256 CBC —Triple DES CBC

MUST: The definition is an absolute requirement of the specification. An implementation must include this feature or function to be in conformance with the specification.

SHOULD: There may exist valid reasons in particular circumstances to ignore this feature or function, but it is recommended that an implementation include the feature or function.

PGP vs. S/MIME

Features	PGP	S/MIME
Full form	PGP is an abbreviation for Pretty Good Privacy.	S/MIME is an abbreviation for Secure/Multipurpose Internet Mail Extension.
Effectively process	It is made to process emails in plain text.	It permits emails that also contain multimedia assets.
Cost	It is less costly than S/MIME.	It is more expensive than PGP.
Dependency	It relies on the user key exchange.	It relies on a hierarchically valid certificate for key exchange.
Usage	It is useful for both personal and organizational purposes.	It is suitable for usage in the industry.
Efficient	It is less efficient.	It is more efficient.
Convenient	It is less convenient.	It is more convenient because all applications are securely transformed.
Public Keys	It has 4096 public keys.	It has only 1024 public keys.
Encryption	It is the standard for secure encryption.	It is a robust encryption standard with some limitations.
Digital Signature	It utilizes Diffie hellman's digital signature.	It utilizes Elgamal's digital signature.
VPN	It may be utilized in VPNs.	It is utilized with email services, not VPNs.

Messages

- *SECURING A MIME ENTITY* S/MIME secures a MIME entity with a signature, encryption, or both.
- *ENVELOPED DATA* An application/pkcs7-mime subtype is used for one of four categories of S/MIME processing, each with a unique s/mime-type parameter.
- *SIGNED DATA* The signedData s/mime-type can be used with one or more signers.
- *CLEAR SIGNING* Clear signing is achieved using the multipart content type with a signed subtype.
- *REGISTRATION REQUEST* Typically, an application or user will apply to a certification
- authority for a public-key certificate.
- *CERTIFICATES-ONLY MESSAGE* A message containing only certificates or a certificate
- revocation list (CRL) can be sent in response to a registration request.

Certificate Processing

- S/MIME uses public-key certificates that conform to version 3 of X.509.
- S/MIME managers and/or users must configure each client with a list of trusted keys and certificate revocation lists.
- The responsibility is local for maintaining the certificates needed to verify incoming signatures and encrypt outgoing messages.
- The certificates are signed by certification authorities.

Certificate Processing … Contd.

USER AGENT ROLE An S/MIME user has several key management functions to perform.

- **Key generation**
  - The user of some related administrative utility (e.g., one associated with LAN management) MUST be capable of generating separate Diffie–Hellman and DSS key pairs and SHOULD be capable of generating RSA key pairs.
  - Each key pair MUST be generated from a good source of nondeterministic random input and be protected securely.
  - A user agent SHOULD generate RSA key pairs with a length in the range of 768 to 1024 bits and MUST NOT generate a length of less than 512 bits.
- **Registration**
  - A user's public key must be registered with a certification authority to receive an X.509 public key certificate.
- **Certificate storage and retrieval**
  - A user requires access to a local list of certificates to verify incoming signatures and to encrypt outgoing messages.
  - Such a list could be maintained by the user or by some local administrative entity on behalf of several users.

Enhanced Security Services

RFC 2634 defines four enhanced security services for S/MIME:

- **Signed receipts**
  - A signed receipt may be requested in a SignedData object.
  - Returning a signed receipt provides proof of delivery to the originator of a message and allows the originator to demonstrate to a third party that the recipient received the message.
- **Security labels**
  - A security label may be included in the authenticated attributes of a SignedData object.
  - A security label is a set of security information regarding the sensitivity of the content that is protected by S/MIME encapsulation.
  - The labels may be used for access control, by indicating which users are permitted access to an object.
- **Secure mailing lists**
  - When a user sends a message to multiple recipients, a certain amount of per-recipient processing is required, including the use of each recipient's public key.
  - The user can be relieved of this work by employing the services of an S/MIME Mail List Agent (MLA).
  - An MLA can take single incoming message, perform the recipient-specific encryption for each recipient, and forward the message.
  - The originator of a message need only send the message to the MLA with encryption performed using the MLA's public key.
- **Signing certificates**
  - This service is used to securely bind a sender's certificate to their signature through a signing certificate attribute.

Pros and Cons of S/MIME

Advantages

- It is available in various modern mail agents like Netscape, MS Outlook, etc.
- It is utilized in commercial or industrial settings.
- It ensures the message's validity and security.
- The digital signature protects the email by using email spoofing.

Disadvantages

- All users are unable to benefit from S/MIME due to the enforced certificate need because some users simply desire encryption.
- All email clients do not support S/MIME signatures.